FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud exposure, target control environment and implementation programme

78.50
READINESS / 100

STRUCTURED
MATURITY BAND

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Contents

Management report — SECTIONS 1–9

1 · Where the organisation stands

2 · What is driving the position

3 · Where the material fraud exposure sits

4 · Fraud scenario portfolio

5 · The control environment management should build

6 · Who must own the response

7 · Decisions leadership must make

8 · What should happen, and in what order

9 · How management will know it is working

Analytical registers — APPENDICES A–F

A · Finding register — 11 entries

B · Fraud risk register — 11 entries

C · Control blueprint register — 11 entries

D · Evidence requirement register — 9 entries

E · 12-month action and assurance register — 31 entries

F · Measurement register — 11 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections. They contain every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

BASIS OF THIS REPORT

This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology: what good practice requires, not observations of what the organisation currently does.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The assessed readiness position

78.50	Structured	6	11	11
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	MATERIAL FINDINGS	CONTROL DESIGNS RECOMMENDED

Domain readiness profile

Fraud governance and accountability	90.00	Strategic
Fraud risk assessment	91.70	Strategic
Ethics, integrity and anti-corruption	86.70	Strategic
Finance, banking and financial reporting	100.00	Strategic
Digital, cyber-enabled and identity fraud	16.00	Reactive
Detection, speak-up and response	86.70	Strategic

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

EXECUTIVE INTERPRETATION

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The patterns beneath the score

The assessment produced 11 material findings. They resolve into 3 connected patterns, ordered by how much of the organisation's critical control population each one affects.

PATTERN	FINDINGS	CRITICAL	HARD GATE	MANAGEMENT QUESTION THIS RAISES
Identity and access challenge Digital, cyber-enabled and identity fraud	8	3	Not recorded	Is authority verified at the points where it can be misused?
Incident response and evidence integrity Digital, cyber-enabled and identity fraud	2	1	Not recorded	When something is suspected, can we contain it and keep the evidence?
Culture and continuous improvement Ethics, integrity and anti-corruption	1	Not recorded	Not recorded	Do people recognise fraud, and does the control environment learn?

Every finding behind these patterns is listed in Appendix A.

WHY THIS MATTERS

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Exposure by control family

11 fraud risks arise from the assessed position. They concentrate in 3 exposure families.

EXPOSURE FAMILY	RISKS	DOMAINS AFFECTED	WHAT THE ORGANISATION IS EXPOSED TO
Identity and access challenge	8	Digital, cyber-enabled and identity fraud	Is authority verified at the points where it can be misused?
Incident response and evidence integrity	2	Digital, cyber-enabled and identity fraud	When something is suspected, can we contain it and keep the evidence?
Culture and continuous improvement	1	Ethics, integrity and anti-corruption	Do people recognise fraud, and does the control environment learn?

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

MANAGEMENT IMPLICATION

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	WARNING INDICATORS	LINKS
A payment instruction received by email is acted on IDENTITY IMPERSONATION	Changed details or urgent payments are processed on the strength of an email.	Acting on payment instructions received by email is how business email compromise succeeds. What the answers show: Payment changes received by email are acted on as received.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	• Business email compromise and payment redirection • Takeover of staff accounts	RISK-FS-D9-02, CI-FS-D9-02
An email account is taken over IDENTITY IMPERSONATION	A mailbox without strong sign-in is used to send or intercept payment instructions.	Most business email compromise starts with an account that has no multi-factor authentication. What the answers show: Email accounts are protected by passwords only.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	• Takeover of staff accounts • Business email compromise and payment redirection • Spoofed or lookalike email in the organisation's name • Criminals impersonating the organisation to customers, suppliers and the public • Slow response that lets losses grow	RISK-FS-D9-01, CI-FS-D9-01
A cloned voice or video instruction is obeyed IDENTITY IMPERSONATION	A caller who sounds or looks like a known person is believed.	Voices and faces can be cloned, so only an agreed verification method holds. What the answers show: Some staff check unusual requests, depending on their own judgement. Pressure triggers verification: only in some areas, cases or periods. Most changes are verified through the old details or another trusted route.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Pressure triggers verification: the answer to "Are requests for secrecy, urgency or skipping normal steps treated as warning signs that trigger verification, whoever appears to be asking?" is yes, across everything it should cover. Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Gift cards and PIN requests banned: the answer to "Are requests to buy gift cards, vouchers or airtime, or to share a one-time PIN, refused outright, whoever seems to be asking?" is yes, across everything it should cover.	• Deepfake voice and video impersonation of executives and staff • Business email compromise and payment redirection • Takeover of staff accounts • SIM swaps and intercepted one-time PINs	RISK-FS-D9-03, CI-FS-D9-03

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
A compromise is not contained quickly INCIDENT CONCEALMENT	Accounts stay compromised while suppliers and customers keep receiving instructions.	What the answers show: There is no plan; each case would be handled from scratch.	A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	• Slow response that lets losses grow • Business email compromise and payment redirection • Takeover of staff accounts	RISK-FS-D9-12, CI-FS-D9-12
Systems that move money are accessed without strong sign-in PRIVILEGED ACCESS MISUSE	Remote access, cloud or banking systems rely on passwords alone.	What the answers show: These systems are protected by passwords only.	It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	• Takeover of staff accounts • Misuse of administrator and third-party access • Theft and sale of personal information	RISK-FS-D9-07, CI-FS-D9-07
A security compromise is not notified INCIDENT CONCEALMENT	The Regulator and affected people are not told, so they cannot protect themselves.	POPIA section 22 requires notification as soon as reasonably possible. What the answers show: A compromise would be handled as it happens, without a set process. Affected people warned: not in place.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. Affected people warned: the answer to "When data is leaked, are affected people warned about follow-up fraud, such as phishing that uses their real details?" is yes, across everything it should cover.	• Theft and sale of personal information • Criminals impersonating the organisation to customers, suppliers and the public • Slow response that lets losses grow	RISK-FS-D9-05, CI-FS-D9-05
Personal information is over-exposed or kept too long PRIVILEGED ACCESS MISUSE	Too many people can reach or export personal information, or records outlive their purpose.	What the answers show: Access is limited for some systems only.	In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	• Theft and sale of personal information • Takeover of staff accounts	RISK-FS-D9-08, CI-FS-D9-08
A help desk reset hands an attacker access PRIVILEGED ACCESS MISUSE	An impersonator persuades the help desk to reset a password or authenticator.	What the answers show: Most resets need verification through a trusted route, such as the person's manager or a number on file.	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	• Social engineering of the IT help desk • Takeover of staff accounts • Misuse of administrator and third-party access	RISK-FS-D9-06, CI-FS-D9-06
Spoofed email in the organisation's name deceives staff, suppliers or customers IDENTITY IMPERSONATION	Emails that appear to come from the organisation's own domain carry false payment instructions.	What the answers show: Domain protected against spoofing: only in some areas, cases or periods.	Domain protected against spoofing: the answer to "Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?" is yes, across everything it should cover.	• Spoofed or lookalike email in the organisation's name • Criminals impersonating the organisation to customers, suppliers and the public	RISK-FS-D9-14, CI-FS-D9-14

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

PATHWAY	HOW IT COULD BEGIN	PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
The organisation's own information helps attackers IDENTITY IMPERSONATION	Published staff details and routines make impersonation easier.	What the answers show: Staff guided on what not to share: not in place.	Staff guided on what not to share: the answer to "Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?" is yes, across everything it should cover.	• Deepfake voice and video impersonation of executives and staff • Business email compromise and payment redirection • Criminals impersonating the organisation to customers, suppliers and the public	RISK-FS-D9-11, CI-FS-D9-11
Staff do not know or understand what is expected THIRD PARTY COLLUSION	Expectations are not communicated in a way people understand, and nobody checks.	What the answers show: Training on joining: only in some areas, cases or periods.	Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	• Unclear standards, so misconduct is excused as normal practice • Inconsistent consequences that signal the rules do not apply to everyone • Staff unable to recognise fraud, including AI-enabled schemes • Corporate criminal liability for bribery by people acting for the organisation	RISK-FS-D3-10, CI-FS-D3-10

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The control programmes

The 11 recommended control designs group into 3 programmes. Each is one coherent piece of work with one accountable executive.

PROGRAMME	CONTROLS	EVIDENCE	MEASURES	ACCOUNTABLE	HORIZON
Identity and access challenge	8	7	8	Head of IT	30 days, 60 days, 90 days
Incident response and evidence integrity	2	2	2	Head of IT	60 days, 90 days
Culture and continuous improvement	1	0	1	People, learning and ethics	90 days

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

CONTROL PROGRAMME SYNTHESIS

Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Programme detail

Identity and access challenge

8 CONTROLS

Is authority verified at the points where it can be misused?

Accountable: Head of IT
Evidence expected · 7 items across 6 controls
Delivery horizon: 30 days, 60 days, 90 days
Effectiveness measures · 8

Controls: CI-FS-D9-01, CI-FS-D9-02, CI-FS-D9-03, CI-FS-D9-06, CI-FS-D9-07, CI-FS-D9-08, CI-FS-D9-11, CI-FS-D9-14

Incident response and evidence integrity

2 CONTROLS

When something is suspected, can we contain it and keep the evidence?

Accountable: Head of IT
Evidence expected · 2 items across 2 controls
Delivery horizon: 60 days, 90 days
Effectiveness measures · 2

Controls: CI-FS-D9-05, CI-FS-D9-12

Culture and continuous improvement

1 CONTROLS

Do people recognise fraud, and does the control environment learn?

Accountable: People, learning and ethics
Evidence expected · 0 items across 0 controls
Delivery horizon: 90 days
Effectiveness measures · 1

Controls: CI-FS-D3-10

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

ROLE	STANDING	CONTROLS	DECISIONS	EVIDENCE	ESCALATION RESPONSIBILITY
Head of IT	executive accountability	10	1	6	Not recorded
Chief Financial Officer	executive accountability	1	Not recorded	2	Not recorded
Chief Executive / Managing Director	executive accountability	Not recorded	2	Not recorded	Not recorded
People, learning and ethics	process ownership	1	1	Not recorded	Not recorded
HR lead	process ownership	1	Not recorded	Not recorded	Not recorded
Information officer (POPIA)	process ownership	1	Not recorded	1	Not recorded
Communications	process ownership	1	Not recorded	Not recorded	Not recorded
The owners	oversight	Not recorded	Not recorded	Not recorded	Any suspected case of the scheme where staff do not know or understand what is expected, or any case processed without this control: training on joining.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The decision agenda

DECISION	WHY NOW	RECOMMENDED DIRECTION	OWNER	CONSEQUENCE OF DELAY
Name one accountable executive for each area with first-priority schemes open or unsupported: digital and identity (4).	Each scheme needs one person with authority over the process, the system and the people involved.	Head of IT or IT provider for digital and identity.	Chief Executive / Managing Director 30 days	Schemes with no owner stay open, and the gaps that let them happen stay unassigned.
Approve the target design for digital and identity, where 4 first-priority schemes are open or unsupported.	The schemes share processes and owners; designing them together avoids separate partial fixes.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	Head of IT 60 days	Controls are added one at a time and the scheme stays open through the gaps between them.
Decide whether to keep relying on 1 control reported in place whose supporting practices were reported as gaps.	A self-reported control that its own practices do not support can give management comfort it has not earned.	Ask each process owner to confirm in writing how the control works without the missing practices, and close the practices in the next 60 days.	People, learning and ethics 30 days	The scheme is treated as covered when it may not be.
Have the owners receive the status of the 4 first-priority schemes each month until they are closed.	Monthly reporting keeps the schemes visible to the people who can remove blockers.	A one-page scheme status: owner, controls in place, controls outstanding, next date.	Chief Executive / Managing Director 30 days	Progress is not visible until the next assessment.

A recommended direction is MK methodology. The decision remains management's.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The 12-month implementation programme

11 implementation actions, followed by 10 embed-and-evidence checkpoints, and 10 assure-and-review checkpoints across the 12-month programme. 31 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

HORIZON	WORK TYPE	COUNT	PROGRAMMES ADVANCED IN THIS HORIZON
30 days	Implement	2	Identity and access challenge
60 days	Implement	2	Identity and access challenge · Incident response and evidence integrity
90 days	Implement	7	Culture and continuous improvement · Identity and access challenge · Incident response and evidence integrity
3-6 months	Embed & evidence	10	Culture and continuous improvement · Identity and access challenge · Incident response and evidence integrity
6-12 months	Assure & review	10	Culture and continuous improvement · Identity and access challenge · Incident response and evidence integrity

Every programme item, with its dependency and completion criterion, is in Appendix E.

> **IMPLEMENTATION SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

PROGRAMME	MEASURES	CONTROLS	ACCOUNTABLE FOR REPORTING
Identity and access challenge	8	8	Head of IT
Incident response and evidence integrity	2	2	Head of IT
Culture and continuous improvement	1	1	People, learning and ethics

The individual measures are in Appendix F.

> **CONCLUSION**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
MF-FS-D9-02 D9-E-05	Digital, cyber-enabled and identity fraud	Payment changes received by email are acted on as received. Acting on payment instructions received by email is how business email compromise succeeds.	control failure CRITICAL	Changed details or urgent payments are processed on the strength of an email. The method links it to business email compromise and payment redirection and takeover of staff accounts.	RISK-FS-D9-02	CI-FS-D9-02
MF-FS-D9-01 D9-E-01	Digital, cyber-enabled and identity fraud	Email accounts are protected by passwords only. Most business email compromise starts with an account that has no multi-factor authentication.	control failure CRITICAL	A mailbox without strong sign-in is used to send or intercept payment instructions. The method links it to takeover of staff accounts, business email compromise and payment redirection, spoofed or lookalike email in the organisation's name, criminals impersonating the organisation to customers, suppliers and the public and slow response that lets losses grow.	RISK-FS-D9-01	CI-FS-D9-01
MF-FS-D9-03 D9-I-01	Digital, cyber-enabled and identity fraud	Some staff check unusual requests, depending on their own judgement. Voices and faces can be cloned, so only an agreed verification method holds.	control gap CRITICAL	A caller who sounds or looks like a known person is believed. The method links it to deepfake voice and video impersonation of executives and staff, business email compromise and payment redirection, takeover of staff accounts and SIM swaps and intercepted one-time PINs.	RISK-FS-D9-03	CI-FS-D9-03
MF-FS-D9-12 D9-R-02	Digital, cyber-enabled and identity fraud	There is no plan; each case would be handled from scratch. A compromise is not contained quickly is a scheme the method asks about for organisations with this profile.	control failure	Accounts stay compromised while suppliers and customers keep receiving instructions. The method links it to slow response that lets losses grow, business email compromise and payment redirection and takeover of staff accounts.	RISK-FS-D9-12	CI-FS-D9-12
MF-FS-D9-07 D9-A-01	Digital, cyber-enabled and identity fraud	These systems are protected by passwords only. Systems that move money are accessed without strong sign-in is a scheme the method asks about for organisations with this profile.	control failure	Remote access, cloud or banking systems rely on passwords alone. The method links it to takeover of staff accounts, misuse of administrator and third-party access and theft and sale of personal information.	RISK-FS-D9-07	CI-FS-D9-07
MF-FS-D9-05 D9-P-04	Digital, cyber-enabled and identity fraud	A compromise would be handled as it happens, without a set process. POPIA section 22 requires notification as soon as reasonably possible.	control gap CRITICAL	The Regulator and affected people are not told, so they cannot protect themselves. The method links it to theft and sale of personal information, criminals impersonating the organisation to customers, suppliers and the public and slow response that lets losses grow.	RISK-FS-D9-05	CI-FS-D9-05
MF-FS-D9-08 D9-P-01	Digital, cyber-enabled and identity fraud	Access is limited for some systems only. Personal information is over-exposed or kept too long is a scheme the method asks about for organisations with this profile.	control gap	Too many people can reach or export personal information, or records outlive their purpose. The method links it to theft and sale of personal information and takeover of staff accounts.	RISK-FS-D9-08	CI-FS-D9-08
MF-FS-D9-06 D9-A-05	Digital, cyber-enabled and identity fraud	Most resets need verification through a trusted route, such as the person's manager or a number on file. A help desk reset hands an attacker access is a scheme the method asks about for organisations with this profile.	control gap	An impersonator persuades the help desk to reset a password or authenticator. The method links it to social engineering of the IT help desk, takeover of staff accounts and misuse of administrator and third-party access.	RISK-FS-D9-06	CI-FS-D9-06

MF-FS-D9-14 D9-E-02	Digital, cyber-enabled and identity fraud	Partly Spoofed email in the organisation's name deceives staff, suppliers or customers is a scheme the method asks about for organisations with this profile.	control gap	Emails that appear to come from the organisation's own domain carry false payment instructions. The method links it to spoofed or lookalike email in the organisation's name and criminals impersonating the organisation to customers, suppliers and the public.	RISK-FS-D9-14	CI-FS-D9-14
MF-FS-D9-11 D9-O-02	Digital, cyber-enabled and identity fraud	No The organisation's own information helps attackers is a scheme the method asks about for organisations with this profile.	control failure	Published staff details and routines make impersonation easier. The method links it to deepfake voice and video impersonation of executives and staff, business email compromise and payment redirection and criminals impersonating the organisation to customers, suppliers and the public.	RISK-FS-D9-11	CI-FS-D9-11
MF-FS-D3-10 D3-C-04	Ethics, integrity and anti-corruption	Yes, across everything it should cover Staff do not know or understand what is expected is a scheme the method asks about for organisations with this profile.	assurance priority	Expectations are not communicated in a way people understand, and nobody checks. The method links it to unclear standards, so misconduct is excused as normal practice, inconsistent consequences that signal the rules do not apply to everyone, staff unable to recognise fraud, including AI-enabled schemes and corporate criminal liability for bribery by people acting for the organisation.	RISK-FS-D3-10	CI-FS-D3-10

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-FS-D3-10 MF-FS-D3-10	**Because its control is reported in place while training on joining (only in some areas, cases or periods), there is a risk that expectations are not communicated in a way people understand, and nobody checks.**	Training on joining: only in some areas, cases or periods.	Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	Ethics officer or company secretary
RISK-FS-D9-01 MF-FS-D9-01	**Because the controls that stop it were reported as gaps: multi-factor on all email (not in place), there is a risk that a mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.**	Email accounts are protected by passwords only.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	Head of IT or IT provider
RISK-FS-D9-02 MF-FS-D9-02	**Because the controls that stop it were reported as gaps: email never enough on its own (not in place), there is a risk that changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds.**	Payment changes received by email are acted on as received.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	Head of IT or IT provider
RISK-FS-D9-03 MF-FS-D9-03	**Because the controls that stop it were reported as gaps: verification for calls, voice notes and video (only in some areas, cases or periods), pressure triggers verification (only in some areas, cases or periods), changes to call-back details verified (only in some areas, cases or periods) and gift cards and PIN requests banned (only in some areas, cases or periods), there is a risk that a caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds.**	Some staff check unusual requests, depending on their own judgement. Pressure triggers verification: only in some areas, cases or periods. Most changes are verified through the old details or another trusted route. Gift cards and PIN requests banned: only in some areas, cases or periods.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Pressure triggers verification: the answer to "Are requests for secrecy, urgency or skipping normal steps treated as warning signs that trigger verification, whoever appears to be asking?" is yes, across everything it should cover. Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Gift cards and PIN requests banned: the answer to "Are requests to buy gift cards, vouchers or airtime, or to share a one-time PIN, refused outright, whoever seems to be asking?" is yes, across everything it should cover.	Head of IT or IT provider
RISK-FS-D9-05 MF-FS-D9-05	**Because the controls that stop it were reported as gaps: compromises reported as POPIA requires (only in some areas, cases or periods) and affected people warned (not in place), there is a risk that the Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible.**	A compromise would be handled as it happens, without a set process. Affected people warned: not in place.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. Affected people warned: the answer to "When data is leaked, are affected people warned about follow-up fraud, such as phishing that uses their real details?" is yes, across everything it should cover.	Head of IT or IT provider
RISK-FS-D9-06 MF-FS-D9-06	**Because the controls that stop it were reported as gaps: help desk resets verified (only in some areas, cases or periods), there is a risk that an impersonator persuades the help desk to reset a password or authenticator.**	Most resets need verification through a trusted route, such as the person's manager or a number on file.	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	Head of IT or IT provider
RISK-FS-D9-07 MF-FS-D9-07	**Because the controls that stop it were reported as gaps: multi-factor on critical systems (not in place), there is a risk that remote access, cloud or banking systems rely on passwords alone.**	These systems are protected by passwords only.	It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	Head of IT or IT provider
RISK-FS-D9-08 MF-FS-D9-08	**Because the controls that stop it were reported as gaps: access to personal information limited (only in some areas, cases or periods), there is a risk that too many people can reach or export personal information, or records outlive their purpose.**	Access is limited for some systems only.	In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	Head of IT or IT provider

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	RISK	POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-FS-D9-11 MF-FS-D9-11	**Because the controls that stop it were reported as gaps: staff guided on what not to share (not in place), there is a risk that published staff details and routines make impersonation easier.**	Staff guided on what not to share: not in place.	Staff guided on what not to share: the answer to "Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?" is yes, across everything it should cover.	Head of IT or IT provider
RISK-FS-D9-14 MF-FS-D9-14	**Because the controls that stop it were reported as gaps: domain protected against spoofing (only in some areas, cases or periods), there is a risk that emails that appear to come from the organisation's own domain carry false payment instructions.**	Domain protected against spoofing: only in some areas, cases or periods.	Domain protected against spoofing: the answer to "Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?" is yes, across everything it should cover.	Head of IT or IT provider
RISK-FS-D9-12 MF-FS-D9-12	**Because the controls that stop it were reported as gaps: compromise playbook (not in place), there is a risk that accounts stay compromised while suppliers and customers keep receiving instructions.**	There is no plan; each case would be handled from scratch.	A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	Head of IT or IT provider

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Control blueprint register

Recommended control standard for each finding. This is MK methodology: what good practice requires, not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

ASSESSED STATE KEY

- Training on joining: only in some areas, cases or periods.
- Email accounts are protected by passwords only.
- Payment changes received by email are acted on as received.
- Some staff check unusual requests, depending on their own judgement. Pressure triggers verification: only in some areas, cases or periods. Most changes are verified through the old details or another trusted route. Gift cards and PIN requests banned: only in some areas, cases or periods.
- A compromise would be handled as it happens, without a set process. Affected people warned: not in place.
- Most resets need verification through a trusted route, such as the person's manager or a number on file.
- These systems are protected by passwords only.
- Access is limited for some systems only.
- Staff guided on what not to share: not in place.
- Domain protected against spoofing: only in some areas, cases or periods.
- There is no plan; each case would be handled from scratch.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
CI-FS-D3-10 D3-C-04 90 days	**Stop the scheme where staff do not know or understand what is expected.**	1. Training on joining: the answer to "Do all employees receive fraud and ethics training when they join?" is yes, across everything it should cover.	STATE 1	HR lead or ethics officer The owners	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?
CI-FS-D9-01 D9-E-01 30 days	**Stop the scheme where an email account is taken over.**	1. Multi-factor on all email: Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	STATE 2	Head of IT or IT provider The owners	Continuous, with monthly review	Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
CI-FS-D9-02 D9-E-05 30 days	**Stop the scheme where a payment instruction received by email is acted on.**	1. Email never enough on its own: An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	STATE 3	Head of IT or IT provider The owners	Continuous, with monthly review	Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-FS-D9-03 D9-I-01 60 days	**Stop the scheme where a cloned voice or video instruction is obeyed.**	1. Verification for calls, voice notes and video: An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. 2. Pressure triggers verification: the answer to "Are requests for secrecy, urgency or skipping normal steps treated as warning signs that trigger verification, whoever appears to be asking?" is yes, across everything it should cover. 3. Changes to call-back details verified: Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. 4. Gift cards and PIN requests banned: the answer to "Are requests to buy gift cards, vouchers or airtime, or to share a one-time PIN, refused outright, whoever seems to be asking?" is yes, across everything it should cover.	STATE 4	CFO and head of IT together The owners	Every payment or change instruction received electronically	Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
CI-FS-D9-05 D9-P-04 60 days	**Stop the scheme where a security compromise is not notified.**	1. Compromises reported as POPIA requires: A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. 2. Affected people warned: the answer to "When data is leaked, are affected people warned about follow-up fraud, such as phishing that uses their real details?" is yes, across everything it should cover.	STATE 5	Head of IT or information security The owners	As each case arises, with a monthly review by the process owner	Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
CI-FS-D9-06 D9-A-05 90 days	**Stop the scheme where a help desk reset hands an attacker access.**	1. Help desk resets verified: Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	STATE 6	Head of IT or IT provider The owners	Every joiner, mover and leaver, and quarterly review	Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.
CI-FS-D9-07 D9-A-01 90 days	**Stop the scheme where systems that move money are accessed without strong sign-in.**	1. Multi-factor on critical systems: It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	STATE 7	Head of IT or IT provider The owners	Every joiner, mover and leaver, and quarterly review	Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-FS-D9-08 D9-P-01 90 days	**Stop the scheme where personal information is over-exposed or kept too long.**	1. Access to personal information limited: In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	STATE 8	Information officer (POPIA) The owners	As each case arises, with a monthly review by the process owner	Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.
CI-FS-D9-11 D9-O-02 90 days	**Stop the scheme where the organisation's own information helps attackers.**	1. Staff guided on what not to share: the answer to "Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?" is yes, across everything it should cover.	STATE 9	Communications or marketing manager The owners	As each case arises, with a monthly review by the process owner	Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?
CI-FS-D9-14 D9-E-02 90 days	**Stop the scheme where spoofed email in the organisation's name deceives staff, suppliers or customers.**	1. Domain protected against spoofing: the answer to "Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?" is yes, across everything it should cover.	STATE 10	Head of IT or IT provider The owners	Continuous, with monthly review	Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?
CI-FS-D9-12 D9-R-02 90 days	**Stop the scheme where a compromise is not contained quickly.**	1. Compromise playbook: A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	STATE 11	Head of IT or information security The owners	As each case arises, with a monthly review by the process owner	Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

Identity and access challenge

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D9-01	**The email security report showing multi-factor status for every account, including shared mailboxes.**	That multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions	Covers every case in the period, not a selection	Head of IT or IT provider Continuous, with monthly review
CI-FS-D9-02	**The written rule, staff communication, call-back records for a sample of requests.**	That an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it	Covers every case in the period, not a selection	Head of IT or IT provider Continuous, with monthly review
CI-FS-D9-03	**The verification procedure, briefing records for executives, simulation results.**	That an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it	Covers every case in the period, not a selection	CFO and head of IT together Every payment or change instruction received electronically
	Change records for supplier and executive contact details, how each change was confirmed.	That every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used	Covers every case in the period, not a selection	CFO and head of IT together Every payment or change instruction received electronically
CI-FS-D9-06	**The help desk reset procedure, reset logs, social engineering test results.**	That every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel	Covers every case in the period, not a selection	Head of IT or IT provider Every joiner, mover and leaver, and quarterly review
CI-FS-D9-07	**Multi-factor coverage reports for remote access, cloud and banking systems.**	That it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data	Covers every case in the period, not a selection	Head of IT or IT provider Every joiner, mover and leaver, and quarterly review
CI-FS-D9-08	**Role-based access settings, export restrictions, access reviews.**	That in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged	Covers every case in the period, not a selection	Information officer (POPIA) As each case arises, with a monthly review by the process owner

Incident response and evidence integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-FS-D9-05	**The breach response procedure, notification templates, records of past notifications.**	That a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly	Covers every case in the period, not a selection	Head of IT or information security As each case arises, with a monthly review by the process owner
CI-FS-D9-12	**The incident plan for email compromise, its contact list, test or incident records.**	That a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles	Covers every case in the period, not a selection	Head of IT or information security As each case arises, with a monthly review by the process owner

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
30 days	Implement	Close the scheme where an email account is taken over: put in place multi-factor on all email.	Head of IT or IT provider	The email security report showing multi-factor status for every account, including shared mailboxes.	Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
30 days	Implement	Close the scheme where a payment instruction received by email is acted on: put in place email never enough on its own.	Head of IT or IT provider	The written rule, staff communication, call-back records for a sample of requests.	Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
60 days	Implement	Close the scheme where a cloned voice or video instruction is obeyed: put in place verification for calls, voice notes and video, pressure triggers verification, changes to call-back details verified and gift cards and PIN requests banned.	Head of IT or IT provider	The verification procedure, briefing records for executives, simulation results. Change records for supplier and executive contact details, how each change was confirmed.	Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
60 days	Implement	Close the scheme where a security compromise is not notified: put in place compromises reported as POPIA requires and affected people warned.	Head of IT or IT provider	The breach response procedure, notification templates, records of past notifications.	Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
90 days	Implement	Confirm with HR lead or ethics officer how code accessible to staff operates and put in place training on joining.	Ethics officer or company secretary	HR lead or ethics officer confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?
90 days	Implement	Close the scheme where a help desk reset hands an attacker access: put in place help desk resets verified.	Head of IT or IT provider	The help desk reset procedure, reset logs, social engineering test results.	Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.
90 days	Implement	Close the scheme where systems that move money are accessed without strong sign-in: put in place multi-factor on critical systems.	Head of IT or IT provider	Multi-factor coverage reports for remote access, cloud and banking systems.	Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.
90 days	Implement	Close the scheme where personal information is over-exposed or kept too long: put in place access to personal information limited.	Head of IT or IT provider	Role-based access settings, export restrictions, access reviews.	Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.
90 days	Implement	Close the scheme where the organisation's own information helps attackers: put in place staff guided on what not to share.	Head of IT or IT provider	Communications or marketing manager confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?

90 days	Implement	Close the scheme where spoofed email in the organisation's name deceives staff, suppliers or customers: put in place domain protected against spoofing.	Head of IT or IT provider	Head of IT or IT provider confirms in writing that the controls operate for every case.	Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?
90 days	Implement	Close the scheme where a compromise is not contained quickly: put in place compromise playbook.	Head of IT or IT provider	The incident plan for email compromise, its contact list, test or incident records.	Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Ethics officer or company secretary	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Every joiner, mover and leaver, and quarterly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Every joiner, mover and leaver, and quarterly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.

3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous, with monthly review), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (As each case arises, with a monthly review by the process owner), with a management sample and any exceptions recorded.	Head of IT or IT provider	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.
6-12 months	Assure & review	A management or assurance review of CI-FS-D3-10 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?	Ethics officer or company secretary	Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?	Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-01 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	Head of IT or IT provider	Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-02 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	Head of IT or IT provider	Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-05 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	Head of IT or IT provider	Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-06 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	Head of IT or IT provider	Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.

6-12 months	Assure & review	A management or assurance review of CI-FS-D9-07 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	Head of IT or IT provider	Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-08 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	Head of IT or IT provider	Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-11 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?	Head of IT or IT provider	Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?	Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-14 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?	Head of IT or IT provider	Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?	Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?
6-12 months	Assure & review	A management or assurance review of CI-FS-D9-12 covering effectiveness, exception trend and dependency, evidenced against: Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	Head of IT or IT provider	Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.

FICTIONAL PROTOTYPE. Staged review answers from a fictional organisation. All figures are test fixtures, not an approved score.

Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

Identity and access challenge

MEASURE	CONTROLS IT COVERS
Management's own records show, for every case in the period: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	CI-FS-D9-01
Management's own records show, for every case in the period: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	CI-FS-D9-02
Management's own records show, for every case in the period: an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.	CI-FS-D9-03
Management's own records show, for every case in the period: every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	CI-FS-D9-06
Management's own records show, for every case in the period: it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	CI-FS-D9-07
Management's own records show, for every case in the period: in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	CI-FS-D9-08
Management's own records show that every case in the period passes this test: Are staff guided on what not to share about their work online, such as who approves payments or when executives are travelling?	CI-FS-D9-11
Management's own records show that every case in the period passes this test: Is the organisation's email domain protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject?	CI-FS-D9-14

Incident response and evidence integrity

MEASURE	CONTROLS IT COVERS
Management's own records show, for every case in the period: a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	CI-FS-D9-05
Management's own records show, for every case in the period: a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	CI-FS-D9-12

Culture and continuous improvement

MEASURE	CONTROLS IT COVERS
Management's own records show that every case in the period passes this test: Do all employees receive fraud and ethics training when they join?	CI-FS-D3-10